die Mobiliar

Governance und Compliance in der DevOps 8

Stefan Johner, Christof Leuenberger, Mathias Schnydrig

Vorstellung

v.l.n.r. Stefan Johner, Mathias Schnydrig, Christof Leuenberger

Cloud Grundsätze der Mobiliar für Eigenentwicklung

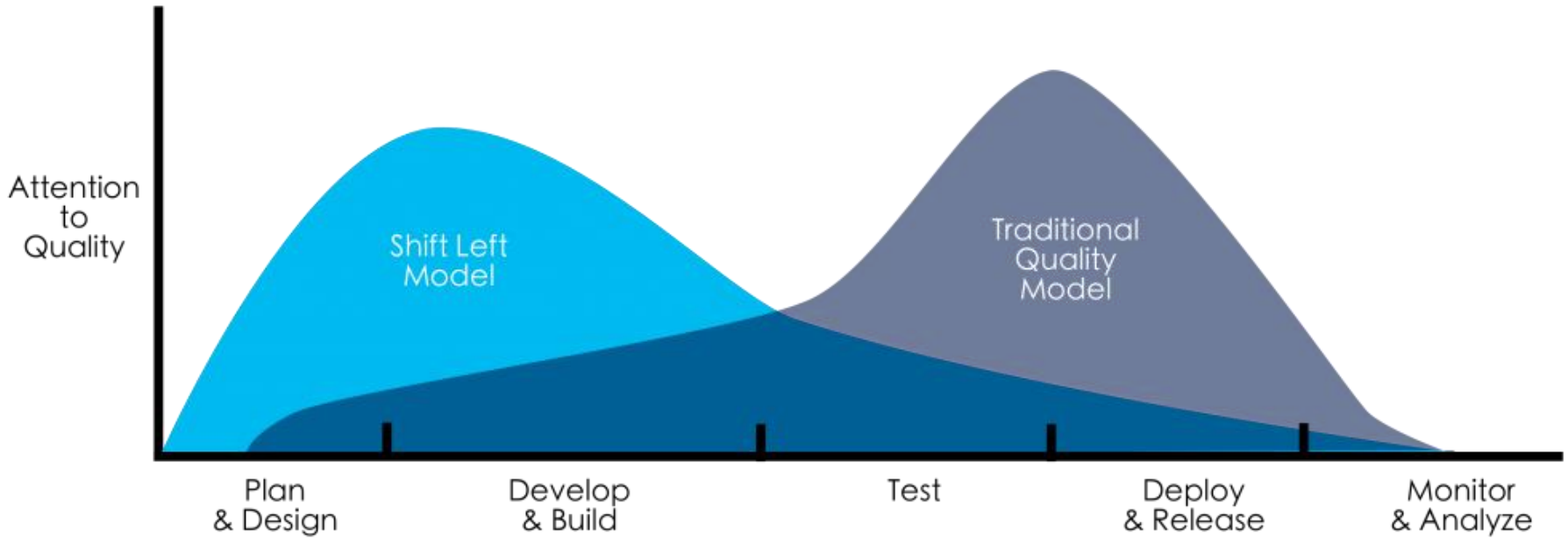
Higher Level Services

Zero Trust

Standard Schnittstellen

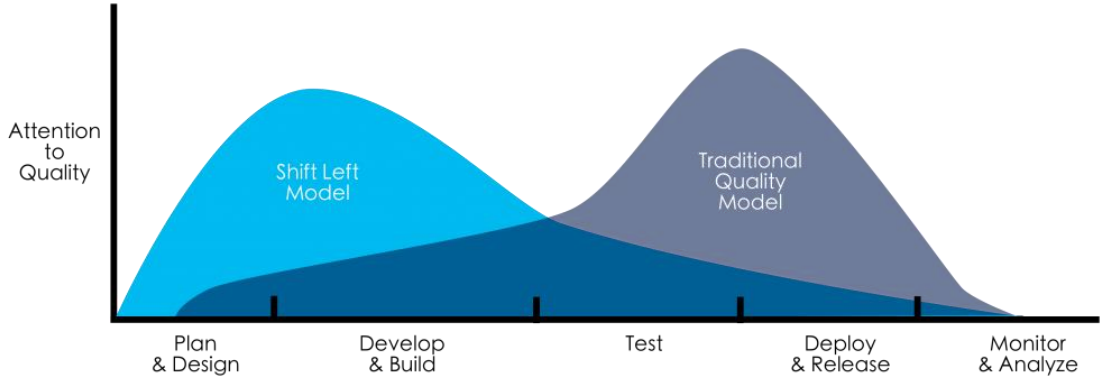
Everything as Code

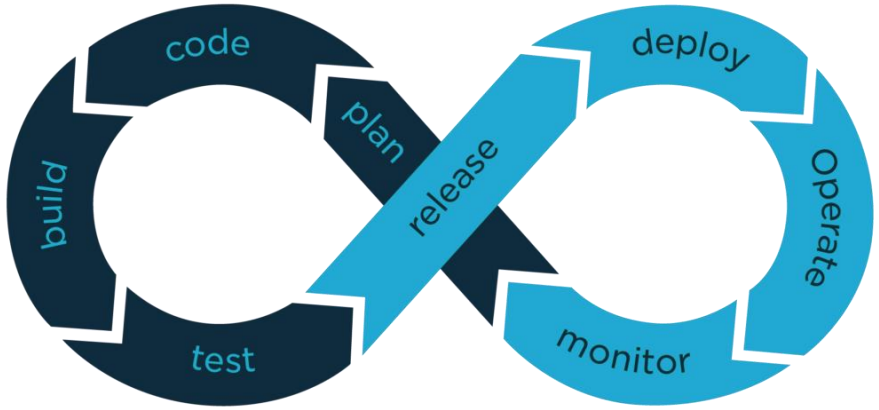
Shift Left



https://devopedia.org/shift-left

Shift Left – DevOps





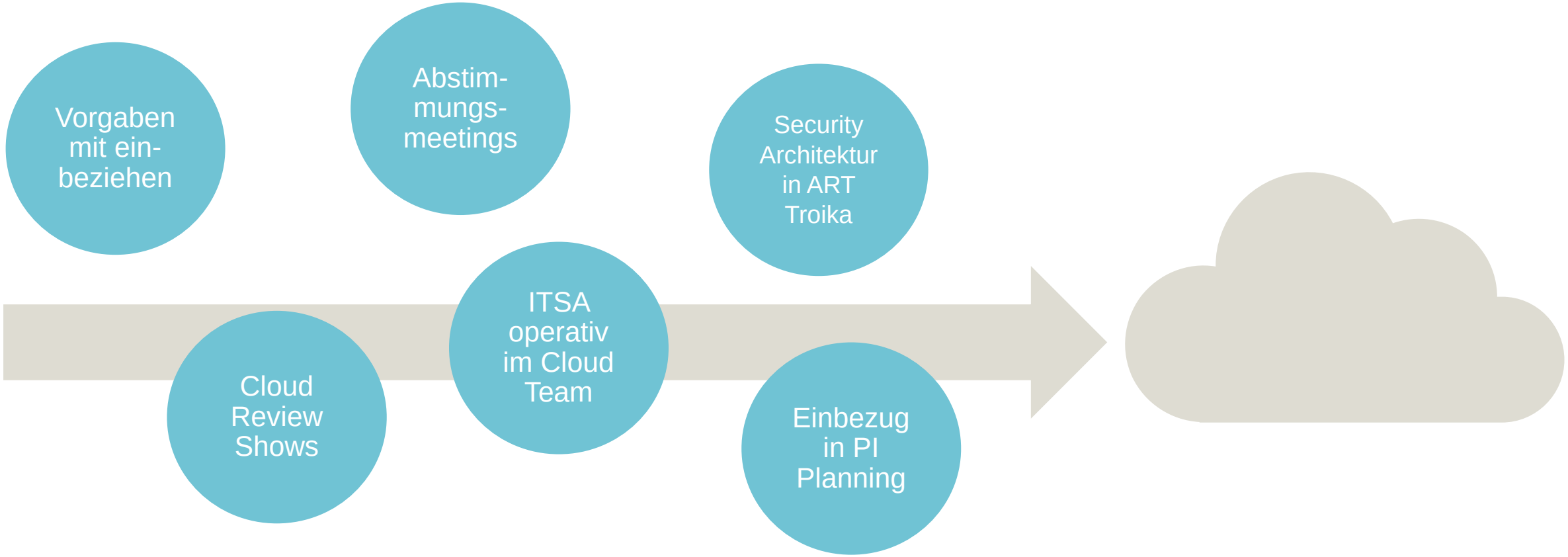
Compliance

in der Cloud sicherstellen

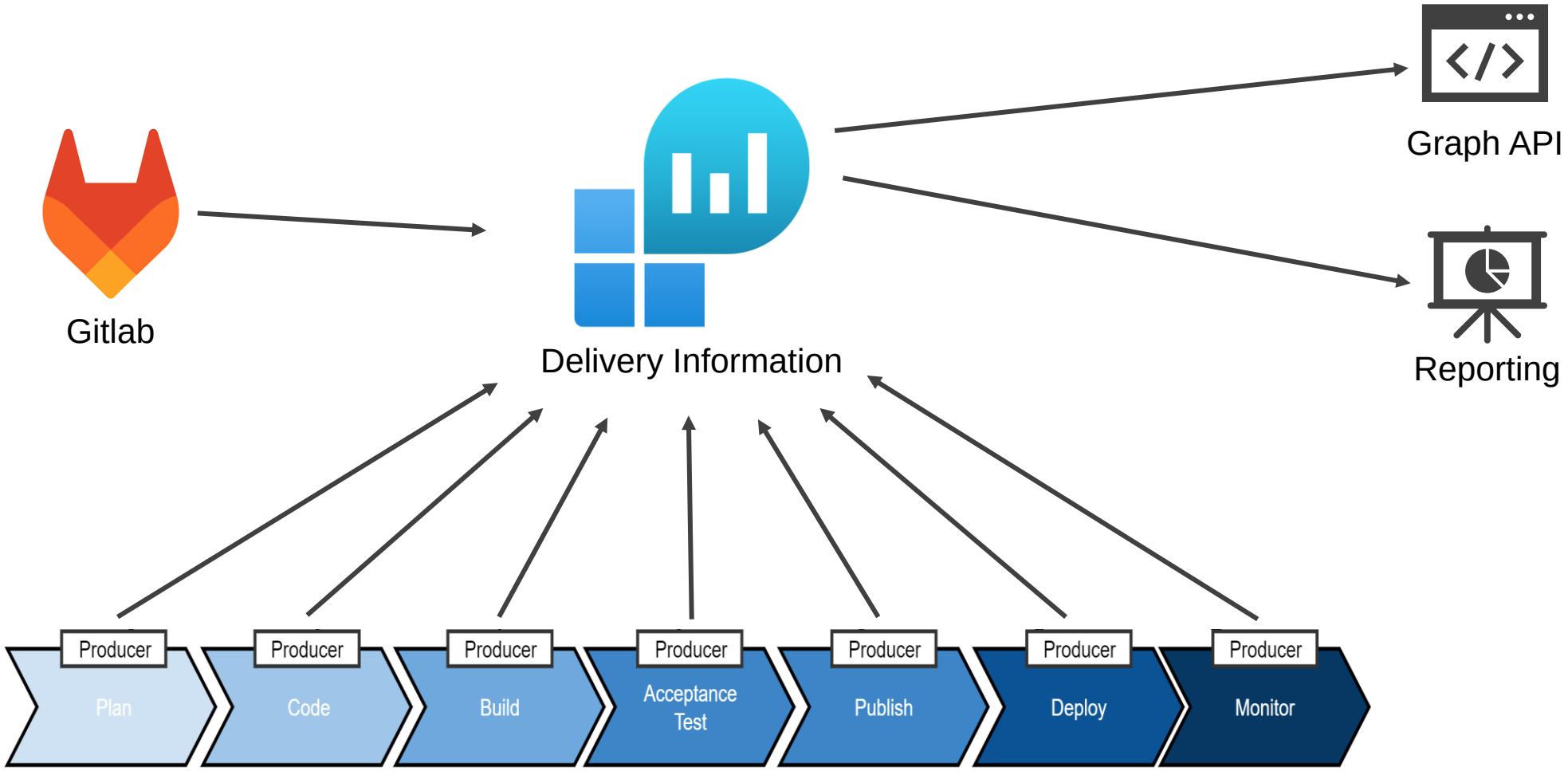
die Mobiliar

MORDAC, THE PREVENTER OF INFORMATION SERVICES.
SECURITY IS MORE IMPORTANT THAN USABILITY.
scottadams@aol.com
www.dilbert.com
IN A PERFECT WORLD, NO ONE WOULD BE ABLE TO USE ANYTHING.
© 2007 Scott Adams, Inc./Dist. by UFS, Inc.
11-16-07
To complete the log-in procedure, stare directly at the sun.

Zusammenarbeit mit CISO & IT Security Architektur



Transparenz und Steuerung des Deployment-Prozesses



```
deployment_CL
| where stage_s has "prod"
| summarize arg_max(event_date_t, *) by tk_id_s
| limit 100
```

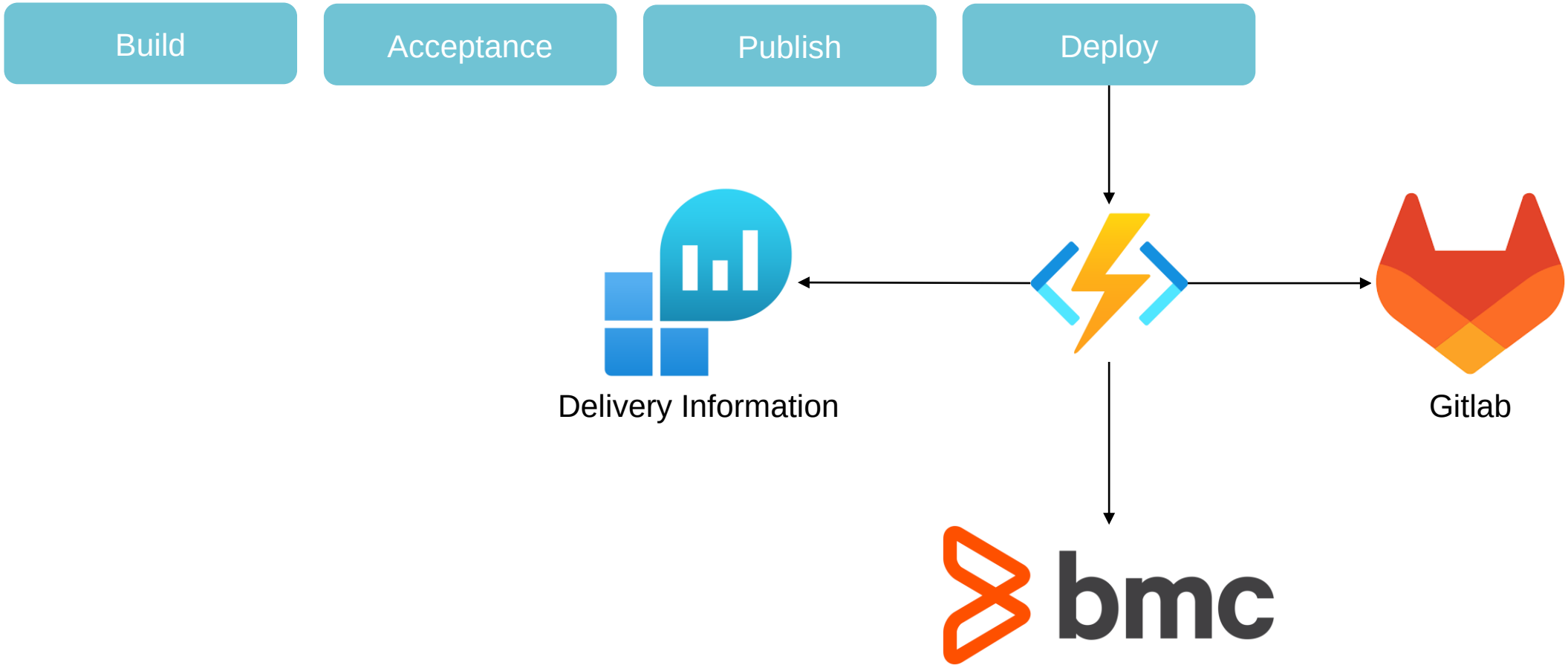
Results Chart

TimeGenerated [UTC]	tk_id_s	event_date_t [UTC]	tech_stack_name_s	tech_stack_version_s
6/7/2022, 3:13:40.277 PM	dlp-runnerpool-corerunnertest...	6/7/2022, 3:13:39.768 PM	CIN-System	2.12.2624
6/7/2022, 12:11:53.542 PM	cos-availability-be-fn	6/7/2022, 12:11:52.934 PM	Go-Function	1.2.13051
6/7/2022, 12:36:31.903 PM	glu-test-minimalist-service	6/7/2022, 12:36:31.281 PM	Gluon	0.1.27
6/7/2022, 12:38:01.940 PM	glu-test-order-service	6/7/2022, 12:38:01.300 PM	Gluon	0.1.27
6/7/2022, 12:45:12.970 PM	rwc-roadmap-rwc	6/7/2022, 12:45:12.228 PM	RWC	13.0
6/7/2022, 1:40:43.991 PM	crt-kubedashboard-iac	6/7/2022, 1:40:43.348 PM	CIN-System	2.13.2793
6/7/2022, 2:47:09.409 PM	dlp-runnerpool-build-iac	6/7/2022, 2:47:09.165 PM	CIN-System	main
6/7/2022, 2:42:18.226 PM	rwc-b2c-components-showcas...	6/7/2022, 2:42:17.648 PM	RWC	13.0
6/7/2022, 12:16:08.262 PM	had-showcase-complex-dbxser...	6/7/2022, 12:16:07.841 PM	Hadron-DBXService	1.0.266
6/7/2022, 12:48:06.566 PM	glu-test-inventory-service	6/7/2022, 12:48:06.011 PM	Gluon	0.1.27
6/7/2022, 12:55:25.591 PM	glu-test-shipment-service	6/7/2022, 12:55:25.146 PM	Gluon	0.1.27
6/7/2022, 12:57:56.060 PM	dlp-runnerpool-deploy-iac	6/7/2022, 12:57:55.709 PM	CIN-System	main
6/7/2022, 3:47:02.812 PM	cin-terraform-registry-webapp	6/7/2022, 3:47:02.410 PM	Go-Service	1.1.11526
6/7/2022, 1:23:22.995 PM	had-showcase-simple-dbxservice	6/7/2022, 1:23:22.425 PM	Hadron-DBXService	1.0.350
6/7/2022, 3:13:21.054 PM	cin-system-pipeline-canary	6/7/2022, 3:13:20.641 PM	CIN-System	2.13.2793
6/7/2022, 3:12:56.453 PM	rwc-uxframework-showcase-rwc	6/7/2022, 3:12:55.815 PM	RWC	12.0
6/7/2022, 12:21:32.839 PM	dlp-gitlabgov-backup-fn	6/7/2022, 12:21:32.295 PM	Go-Function	1.2.13051
6/7/2022, 12:50:46.930 PM	cos-availability-fn	6/7/2022, 12:50:46.431 PM	Go-Function	1.2.12922

mobitor Team HighFive

Project	SAST	SCA	Test	Pipeline History (14 days)	Pipeline Overview	Deployments
b2e-partnerzuordnung-ng-jslib			90%	Build	Acceptance	Publish	Deploy:preprod	Deploy:jslib
mcs-b2esimple-rwc			90%	Build	Acceptance	Publish	Deploy:preprod	Deploy:prod

Nachvollziehbarkeit von Änderungen in der Produktion



New production deployment for 'cch-checktool-rwc'

Edit

Change Request CRQ000000273825 Risk Level 1 Low Class No Impact

Updated Apr 7, 2022 6:46 AM

More

Closed

Target date is Today at 7:01 AM

0000000000

Requested For

*Disp APL_Hanuman

Affected Service

Change Reason

Other

Operational Category

Change > Software > Release

Product Category

Software > Geschäftsapplikation > Zugänge Kunden > CarCheck

Description

TK ID: cch-checktool-rwc
TK Version: 1.13.5
Feature Team: hanuman
Contact:
Domain: zuku
Stack: RWC
Pipeline triggerer:
Gitlab Project:
- https://gitlab.com/diemobiliar/zuku/cch/checktool/cch-checktool-rwc
Gitlab Pipeline:
- https://gitlab.com/diemobiliar/zuku/cch/checktool/cch-checktool-rwc/-/pipelines/511015712
Stack URL:
- https://gitlab.com/diemobiliar/it/rwc/deliver/rwc-deliver-stack
Jira references:
- https://jira.mobi.ch/browse/HAN-1234
Differences since last production deployment:
- https://gitlab.com/diemobiliar/zuku/cch/checktool/cch-checktool-rwc/-/compare/f42267d2c5d1469520d0376ddd142e6ffabe4284...74c94ad197412128da7de1dc9b5952e215d1c32d

Peer Review von Codeänderungen

Trunk-based Development

Peer Review

Kritischer Source Code

Mobi.yaml

```yaml
---
version: "2.1"
components:
  - name: "gol-example-service"
    path: ./APP-ONE-DIRECTORY
    metadata:
      annotations:
        team: "The Feature Team"
        contact: "DL_Feature_Team@mobi.ch"
        domain: "it"
      labels:
        distribution: "internal"
        risk-class: "critical"
  - name: "gol-k8s-service-iaclib"
    path: ./APP-TWO-DIRECTORY
    metadata:
      annotations:
        team: "The Feature Team"
        contact: "DL_Feature_Team@mobi.ch"
        domain: "it"
      labels:
        risk-class: "normal
```

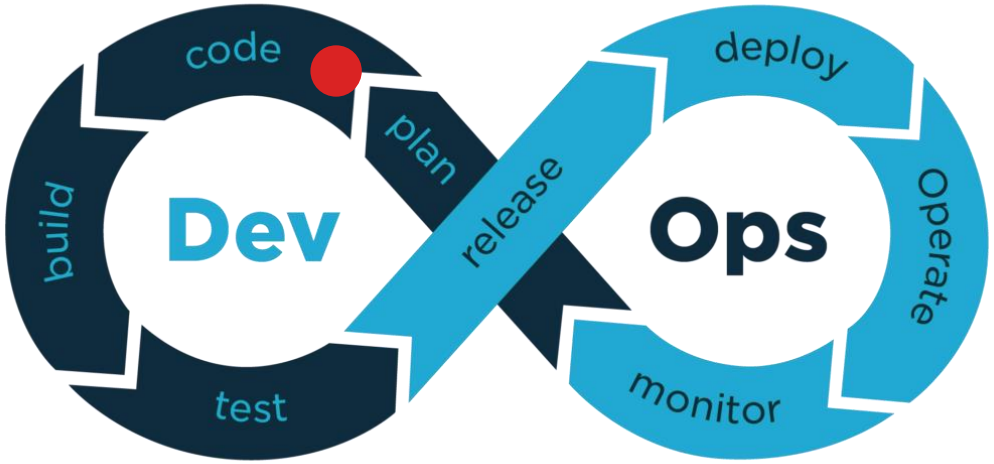
Governance

in der Cloud mit DevSecOps

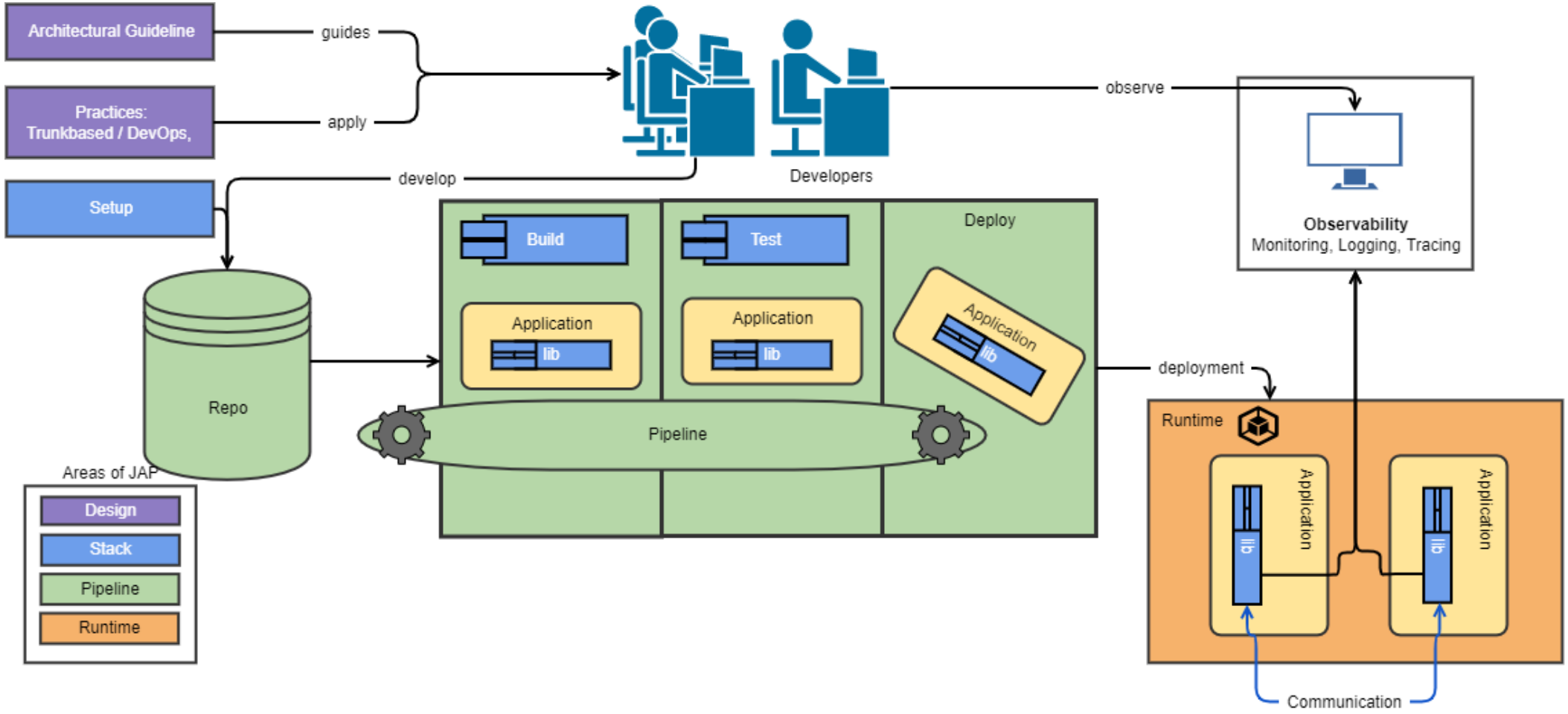
die Mobiliar

Tech Stacks

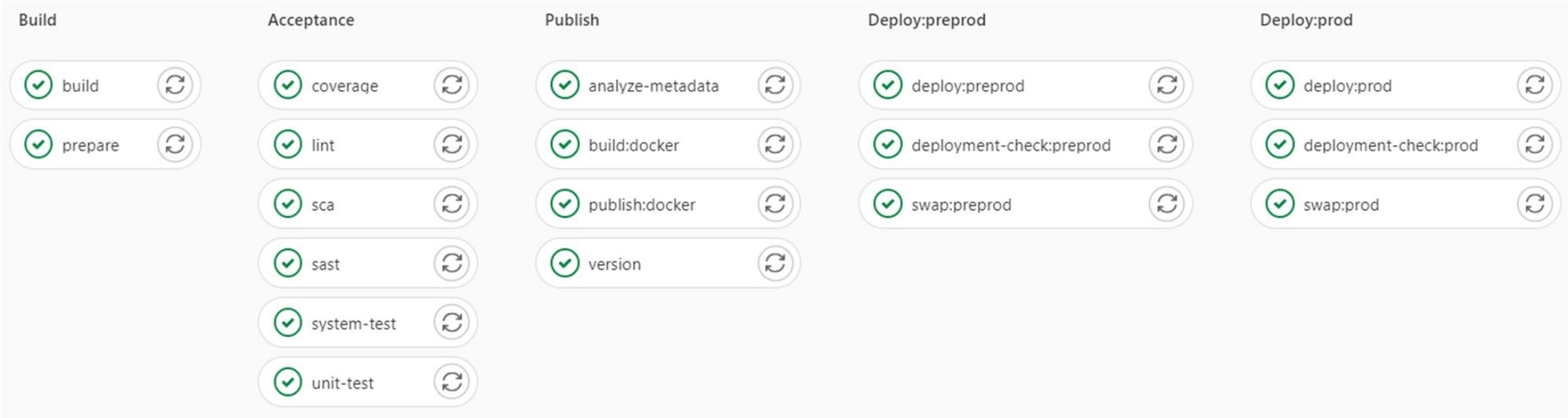
- Applikationsplattform ist eine stabile, performante und einheitliche Basis, auf der Applikationen (Anwendungsprogramme) entwickelt und ausgeführt werden.
- Tech Stacks sind eine Sammlung an Tools, Praktiken und Libraries um mit einer bestimmten Technologie Applikationen für eine Applikationsplattform zu entwickeln
- Wir unterscheiden zwischen Infrastruktur und Business Tech Stacks



Tech Stacks


Architectural Guideline
guides
Practices:
Trunkbased / DevOps,
apply
Setup
develop
Developers
observe
Observability
Monitoring, Logging, Tracing
Repo
Build
Test
Deploy
Application
lib
Application
lib
Application
lib
Pipeline
deployment
Runtime
Application
lib
Application
lib
Communication
Areas of JAP
Design
Stack
Pipeline
Runtime

Tech Stacks

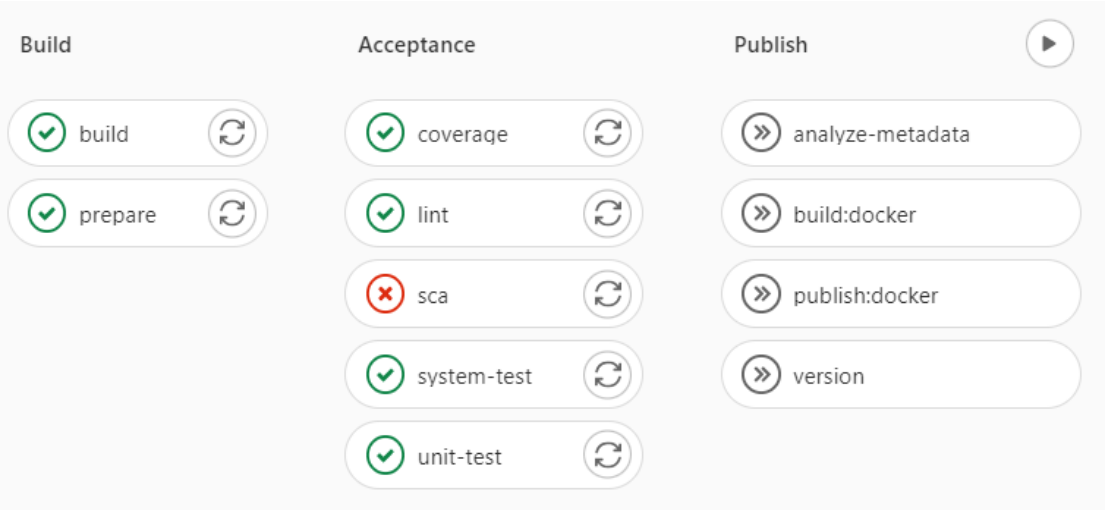

Build
build
prepare
Acceptance
coverage
lint
sca
sast
system-test
unit-test
Publish
analyze-metadata
build:docker
publish:docker
version
Deploy:preprod
deploy:preprod
deployment-check:preprod
swap:preprod
Deploy:prod
deploy:prod
deployment-check:prod
swap:prod

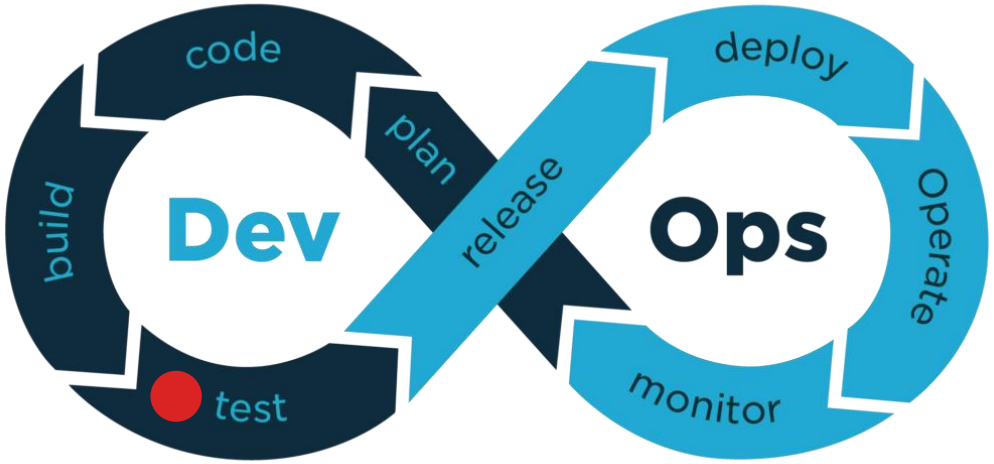
Software Composition Analysis (SCA)

- Unzählige Open Source Software Pakete fliessen heute in einen Software Build. Jedes dieser Artefakte könnte theoretisch kompromittiert sein.
- Security Teams können bei heutigem Entwicklungstempo unmöglich Schritt halten
- Sicherheitslücken können (und treten primär) in transitiv eingebetteten Paketen auf
- Bekannte Sicherheitslücken werden bewertet (CVSS) und in zentralen Datenbanken (z.B. NVD) anhand von Paket Namen und Version eindeutig erfasst (CVE Nummer)
- SCA Software scannt bei jedem Pipeline Durchlauf alle verwendeten Software Pakete sowie deren Lizenzen und vergleicht sie gegen definierte Policies (erlaubte Lizenzen, tolerierte CVSS Level)
- SCA wird bei uns unabhängig des Tech Stacks implementiert

https://snyk.io/series/open-source-security/software-composition-analysis-sca/

Software Composition Analysis (SCA)





Software Composition Analysis (SCA)

Dependency Path

build-angular-12.2.17.tgz

↓

webpack-dev-server-3.11.3.tgz

↓

sockjs-client-1.6.0.tgz

↓

eventsource-1.1.0.tgz

Security Vulnerability

General Details

Name	Severity	CVSS 3 Score	CVSS 2 Score	Date	Modified
CVE-2022-1650	High	9.3	5.8	12-05-2022	31-05-2022

Exposure of Sensitive Information to an Unauthorized Actor in GitHub repository eventsource/eventsource prior to v2.0.2.

CVSS 3 - Base Score Metrics

Exploitability Metrics

- Attack Vector (AV): NETWORK
- Attack Complexity (AC): LOW
- Privileges Required (PR): NONE
- User Interaction (UI): REQUIRED
- Scope (S): CHANGED

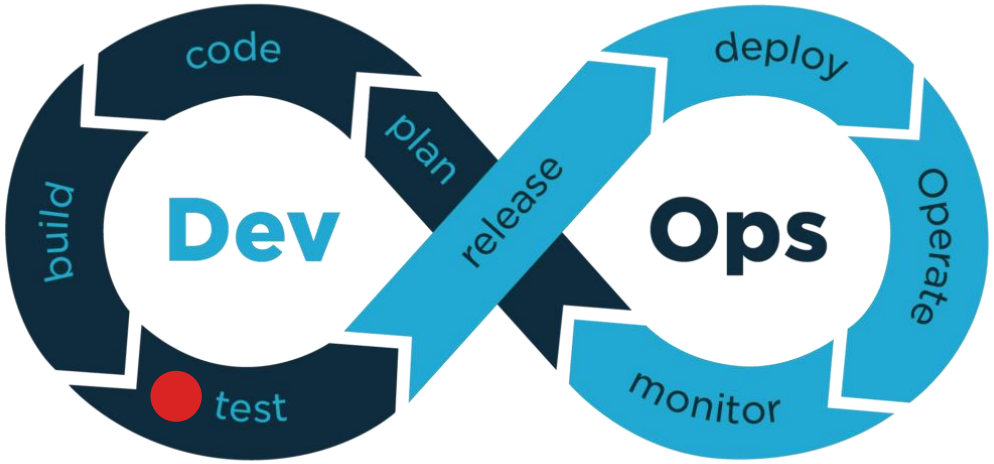
Impact Metrics

- Confidentiality Impact (C): HIGH
- Integrity Impact (I): HIGH
- Availability Impact (A): NONE

Static Application Security Testing (SAST)

- Statische Analyse von Source Code nach Code und Design Mustern, die auf eine potentielle Sicherheitslücke hinweisen
- Innensicht auf die Applikation zur build-time (anstatt zur runtime)
- SAST wird bei uns von den Tech Stacks eigenständig implementiert

Tech Stack	SAST Umsetzung
Frontend (Angular, Node)	Eslint Security Plugin, Semgrep
Backend Services (Java, Quarkus)	SpotBugs
Machine Learning (Python)	Pylint
Cloud Infrastructure (Terraform)	tfsec

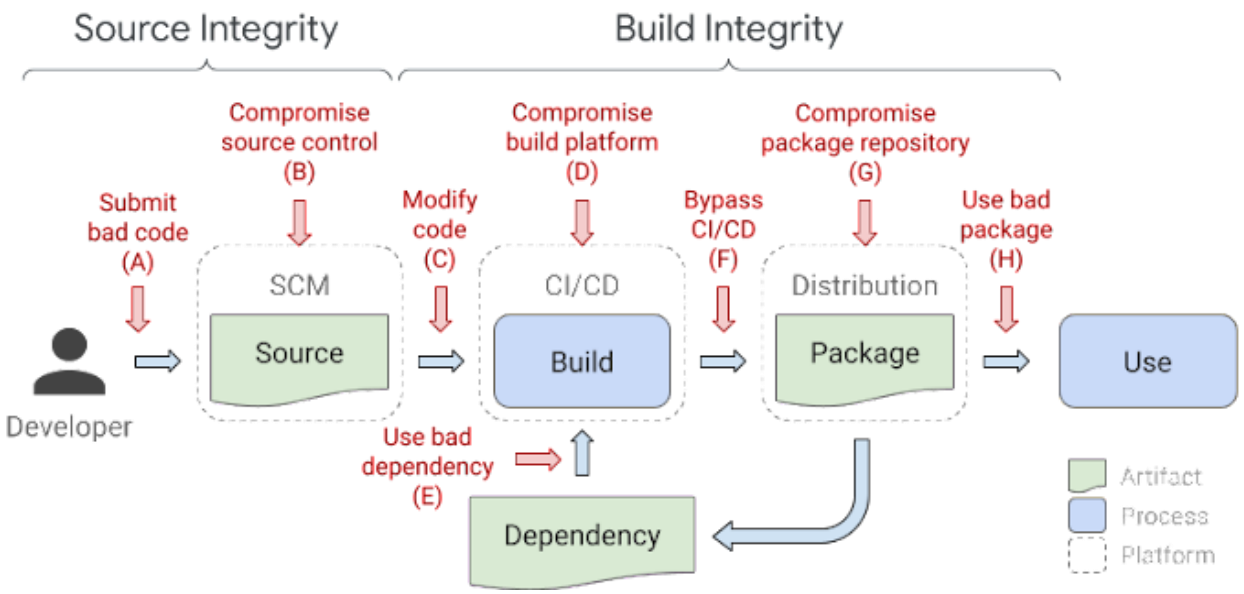


https://about.gitlab.com/resources/whitepaper-seismic-shift-application-security/

SLSA

Supply **C**hain **L**evels for **S**oftware **A**rtifacts (*salsa*)

SLSA ist ein Security Framework – eine Checkliste von Standards und Kontrollen um die Integrität von Software Artefakten sicherzustellen.



https://slsa.dev · https://security.googleblog.com/2021/06/introducing-slsa-end-to-end-framework.html

SLSA

Level 1

Easy to adopt, giving you supply chain visibility and being able to generate provenance

Level 2

Starts to protect against software tampering and adds minimal build integrity guarantees

Level 3

Hardens the infrastructure against attacks, more trust integrated into complex systems

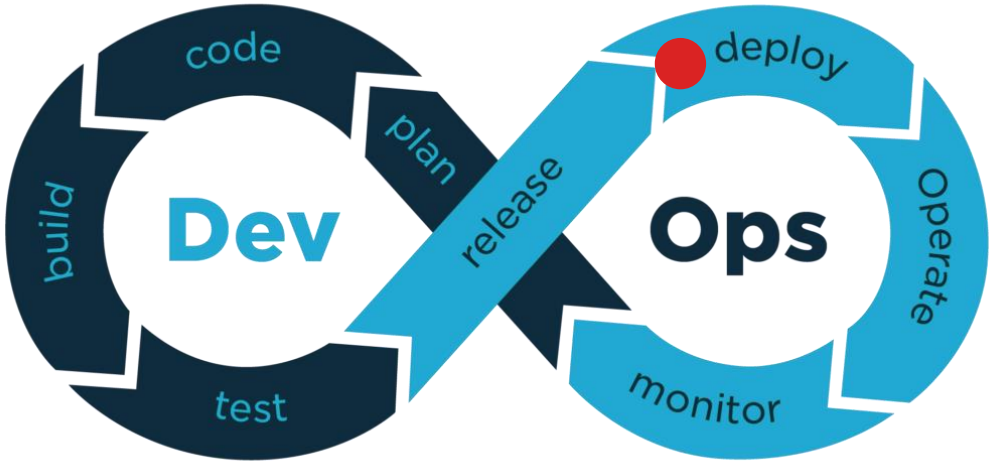
Level 4

The highest assurances of build integrity and measures for dependency management in place

https://slsa.dev/spec/v0.1/levels

Continuous Governance / Policy As Code

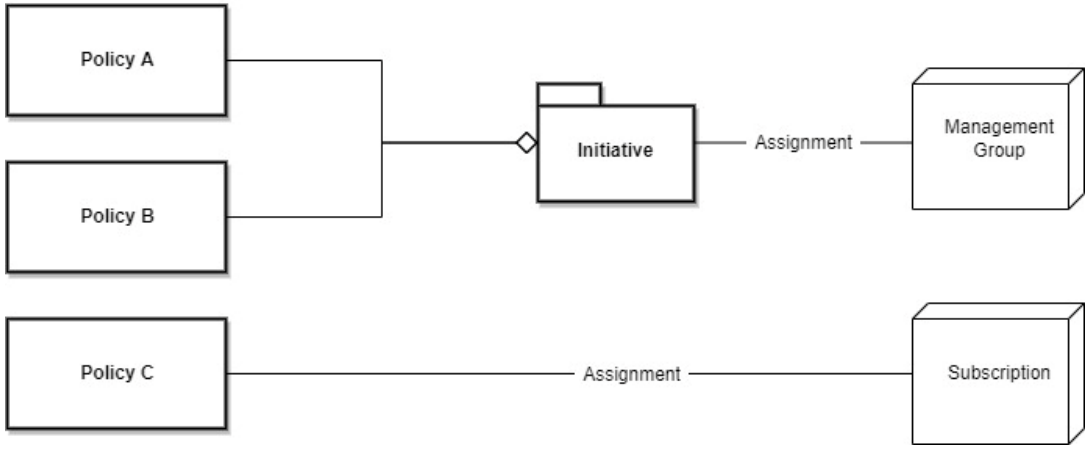
- In Anlehnung an die Herangehensweisen *Infrastructure as Code* und *DevOps* werden *Policies*, *Initiatives* und *Assignments* in Code definiert und in der Pipeline automatisierbar angewandt
- DevOps Teams können selbstständig Ressourcen provisionieren und sind dafür verantwortlich, dass ihre Ressourcen compliant sind.
- Ressourcen die eine Policy verletzen werden beim ersten Deployment-Versuch zu einem Fehler führen. Nachträglich non-compliant Ressourcen werden im Azure Portal ausgewiesen.



https://www.microsoft.com/en-us/insidetrack/enabling-enterprise-governance-in-azure

Continuous Governance / Policy As Code

```
{
  "properties": {
    "displayName": "[Preview]: Storage account public access should be disallowed",
    "policyType": "BuiltIn",
    "mode": "Indexed",
    "description": "Prevent data breaches caused by undesired anonymous access",
    "parameters": {
      "effect": {
        "type": "String",
        "defaultValue": "Audit"
      }
    },
    "policyRule": {
      "if": {
        "allOf": [
          {
            "field": "type",
            "equals": "Microsoft.Storage/storageAccounts"
          },
          {
            "not": {
              "field": "Microsoft.Storage/storageAccounts/allowBlobPublicAccess",
              "equals": "false"
            }
          }
        ]
      },
      "then": {
        "effect": "[parameters('effect')]"
      }
    }
  },
  "type": "Microsoft.Authorization/policyDefinitions"
}
```



Continuous Governance / Policy As Code

Home > Policy

Policy | Compliance

Search (Ctrl+/)

- Overview
- Getting started
- Compliance
- Remediation
- Events

Authoring

- Assignments
- Definitions
- Exemptions

Assign policy | Assign initiative | Refresh

Scope: 33 selected

Type: All definition types

Compliance state: All compliance states

Search: Filter by name or ID...

Overall resource compliance: 95%
5226 out of 5517

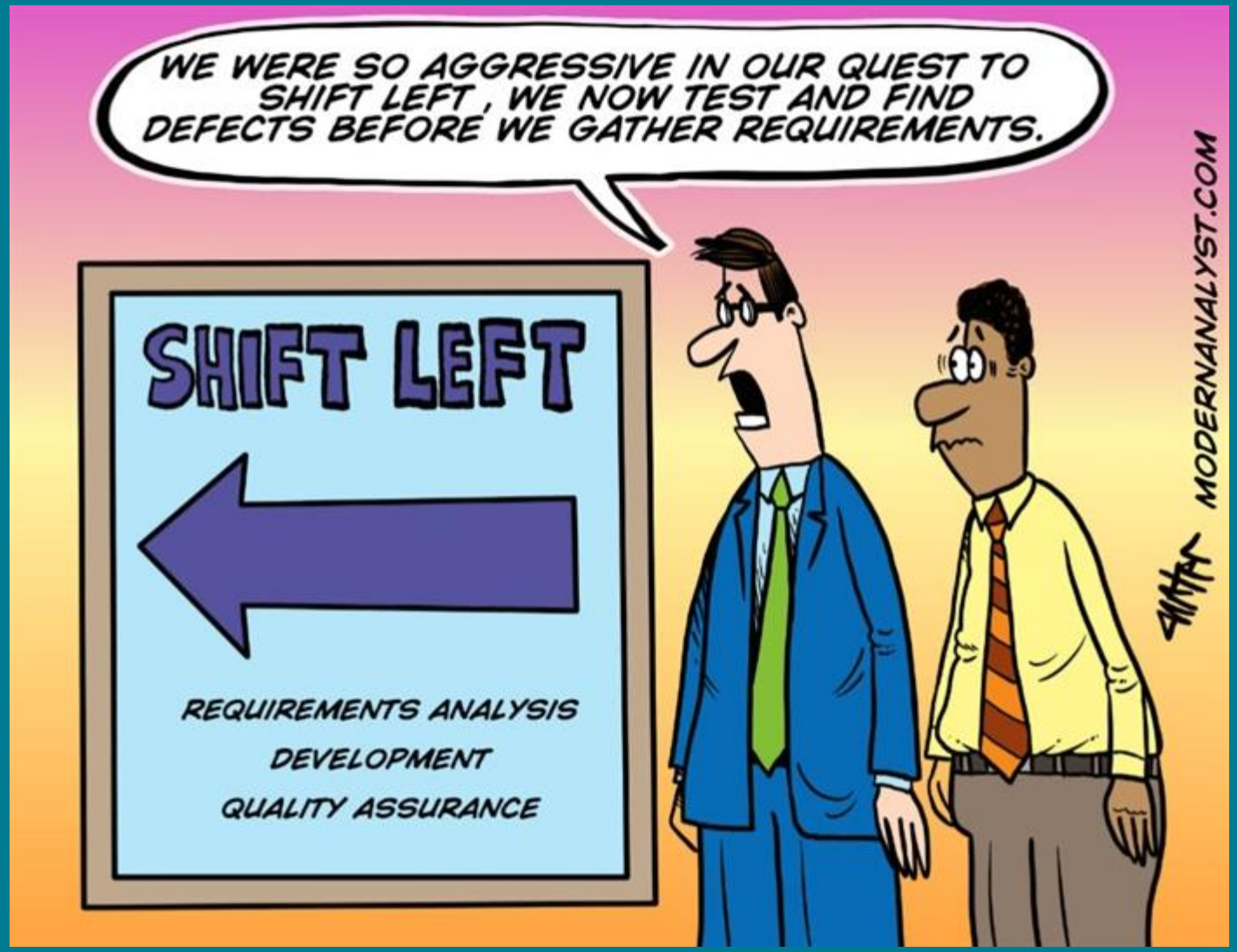
Resources by compliance state: 5'517
5226 - Compliant
0 - Exempt
291 - Non-compli...

Non-compliant initiatives: 11
out of 17

Non-compliant policies: 21
out of 88

Name	Scope	Compliance state	Resource compliance
Storage Account Settings Initiative Assignment	Joint Application Platform	Compliant	100% (306 out of 306)
General Settings	Joint Application Platform	Compliant	100% (4592 out of 4592)
Subscription Tagging Initiative Assignment	Joint Application Platform	Compliant	100% (33 out of 33)
Subscription Diagnostic Settings for SecLogs	0c9409c1-c005-44bc-957b-5ebf0b24...	Compliant	100% (33 out of 33)
TFState Storage Account Settings on PreProd	PreProd	Compliant	100% (92 out of 92)
Storage accounts should restrict network access	pyt-preprod-sub/dsl-base-training-p...	Compliant	100% (1 out of 1)

Fragen?


WE WERE SO AGGRESSIVE IN OUR QUEST TO SHIFT LEFT, WE NOW TEST AND FIND DEFECTS BEFORE WE GATHER REQUIREMENTS.
SHIFT LEFT
REQUIREMENTS ANALYSIS
DEVELOPMENT
QUALITY ASSURANCE
MODERNANALYST.COM